

PPRL 기반 머신러닝 시스템의 프라이버시 리스크 평가 보고서

Black-box Membership Inference Attack 기반 보안 분석

작성자: 권민서

평가 유형: Red Team Privacy Assessment

위협 모델: Black-box ML API

대상 시스템: PPRL 기반 의료 데이터 매칭 모델

작성일: 2025.11

버전: v1.0

GitHub: <https://github.com/Minseo147/cybersecurity-portfolio>

Blog: <https://cyberlab.tistory.com/>

목차

1. Executive Summary.....	4
1.1 평가 배경.....	4
1.2 PPRL 환경 설명.....	4
1.3 공격 구조 요약.....	5
1.4 핵심 결과.....	7
1.5 최종 리스크 판정.....	8
1.6 수행 개요.....	8
2. 분석 목적.....	9
3. PPRL 시스템 개요.....	9
3.1 PPRL 정의.....	9
3.2 의료 데이터 연계 맥락.....	9
3.3 개인정보 보호 설계 의도.....	9
3.4 ML 모델의 역할.....	10
4. 분석 범위.....	10
4.1 대상 시스템.....	10
4.2 분석 포함 범위.....	10
4.3 제외 범위.....	11
5. 위협 모델 정의.....	11
5.1 공격자 가정.....	11
5.2 공격 목표.....	11
5.3 공격 시나리오 개요.....	11
5.4 비즈니스 리스크.....	12
6. 공격 시나리오 상세.....	13
7. 시스템 및 공격 아키텍처.....	13
8. 데이터 구성 및 산출물 정의.....	14
8.1 데이터 자산 개요.....	14
8.2 Target Model 데이터.....	14
8.3 Shadow Dataset 구성.....	15
8.4 Attack Dataset 생성.....	16
8.5 Attack Execution 단계.....	16
8.6 파일 무결성 및 추적성.....	17
9. Membership Inference Attack Execution Framework.....	17
9.1 Phase S-01 - Target Model Baseline 평가.....	17
9.2 Phase S-02 - Shadow Dataset Preparation.....	18
9.3 Phase S-03 - Shadow Model 학습 결과.....	19
9.3.1 Shadow Model Implementation Highlights.....	20
9.4 Confidence 분포 분석.....	22
9.5 Phase S-04 - Attack Model Training.....	22
9.5.1 Threshold 기반 Membership Classifier 구현 로직.....	23
9.6 Phase S-05 - Attack Execution.....	23
9.6.1 Target 적용 로직.....	23
9.7 공격 결과.....	24

10. 결과 심층 분석.....	24
11. PPRL 맥락에서의 보안 영향 평가.....	25
12. 종합 리스크 판정.....	25
13. 대응 방안.....	26
13.1 기술적 대응 방안.....	26
13.2 운영적 대응 방안.....	27
13.3 Layered Defense Model.....	27
14. 한계점.....	27
15. 결론.....	28

1. Executive Summary

1.1 평가 배경

본 보고서는 클라이언트가 제공한 PPRL(Privacy-Preserving Record Linkage) 기반 머신러닝 매칭 모델을 대상으로, Black-box 환경에서 Membership Inference Attack(MIA)을 수행하고 학습 데이터 프라이버시 노출 가능성을 정량적으로 평가한 결과를 정리한 것이다. 평가 대상 모델은 의료 기관 간 데이터 연계를 목적으로 설계되었으며, 직접 식별자를 제거한 상태에서 유사도 기반 매칭을 수행한다. 그러나 최근 연구에 따르면, 모델이 직접 개인정보를 노출하지 않더라도 출력 확률 분포의 차이만으로 학습 데이터 포함 여부가 추론될 가능성이 존재한다. 본 분석은 이러한 간접적 노출 가능성을 검증하기 위한 프라이버시 침해 시뮬레이션이다.

공격자는 다음 조건을 가진 것으로 가정하였다:

- 모델 내부 구조 접근 불가
- 학습 데이터 접근 불가
- 모델 파라미터 접근 불가
- 오직 softmax 확률 벡터 관찰 가능

이는 실제 클라우드 기반 ML API 배포 환경에서 현실적으로 가능한 공격자 모델을 반영한다.

1.2 PPRL 환경 설명

대상 시스템은 의료 데이터 연계를 위한 PPRL 기반 매칭 구조로 설계되었다.

PPRL은 다음 보안 목적을 가진다:

- 직접 식별자 제거
- 암호화 또는 해시 기반 비교
- 개인정보 비노출 상태에서 레코드 매칭

본 시스템에서는 Siamese Network 기반 유사도 임베딩 + MLP 분류기(SNN+MLP) 구조가 사용되었다. Siamese 네트워크는 두 레코드 간 임베딩 거리를 학습하며, 최종 MLP는 매칭 여부를 확률 값으로 출력한다.



직접 식별 정보는 보호되지만, 모델의 **confidence** 분포에 차이가 존재할 경우 이는 설계 취지를 우회하는 간접 공격 경로가 될 수 있다.

1.3 공격 구조 요약

본 평가는 **Black-box** 환경을 가정한 **Shadow Model** 기반 **Membership Inference Attack(MIA)** 구조로 수행되었다. 공격 흐름은 피해자 모델 확보 단계와 공격 준비 및 실행 단계를 명확히 구분하여 총 5단계로 구성된다.

S-01 Target Model Training (피해자 모델 확보 단계)

클라이언트가 제공한 SNN+MLP 구조를 기반으로 Target 모델을 재현하고 성능을 검증하였다.

- 입력: target_train.csv, target_test.csv
- 실행: SNN+MLP.ipynb
- 산출물:
 - target_model.h5
 - snn_classifier_model.h5
 - evaluation logs

본 단계는 공격 단계가 아니며, 실제 배포 환경을 가정하기 위한 피해자 모델 확보 단계이다. 이후 공격자는 해당 모델의 내부 구조 및 파라미터에 접근하지 않는다.

S-02 Shadow Dataset Preparation

공격자는 Target 모델의 학습 데이터를 알 수 없으므로, 독립적인 Shadow Dataset을 구성하였다.

- shadow_train.csv / shadow_test.csv
- 6개 비중첩 subset 생성
- 중복률 0%
- row 보존율 100%

Shadow Train → member

Shadow Test → non-member

이 단계에서 공격자는 membership ground-truth를 알고 있다.

S-03 Shadow Model Training

각 subset에 대해 Target과 동일한 아키텍처(SNN+MLP)를 사용하여 Shadow Model을 학습하였다.

- 실행: Shadow_Final.ipynb
- 산출물: Shadow1~6_combined_predictions.csv

목적은 Target 모델과 유사한 confidence 분포 특성을 재현하는 것이다.

S-04 Attack Model Training

Shadow 모델 출력 데이터를 집계하여 Attack Dataset을 구성하였다.

Feature:

- max_confidence
- entropy
- top2_gap
- boundary_distance

Shadow Train → member(1)

Shadow Test → non-member(0)

이를 기반으로 Threshold 기반 Membership Classifier를 학습하였다. 본 단계에서 학습된 모델이 실제 Attack Model이다.

S-05 Attack Execution (Target 적용 단계)

최종적으로 학습된 Attack Model을 Target 모델 출력에 적용하였다.

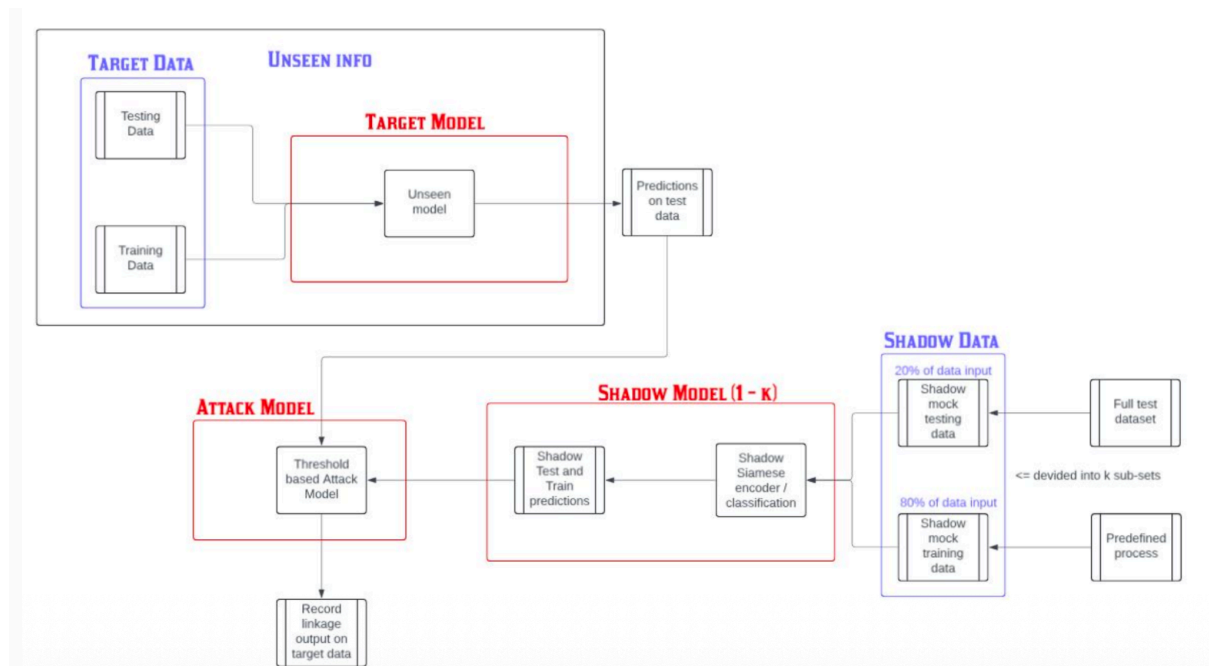
1. victim dataset을 Target 모델에 질의
2. softmax 확률 벡터 수집
3. Attack Model 입력
4. membership 여부 추론

이 단계에서 처음으로 Target 모델이 공격 대상이 된다.

공격 성공 조건

공격 성공 조건은 사전에 다음과 같이 정의하였다:

- Train/Test confidence 평균 차이 존재
- ROC Curve가 대각선 대비 유의미한 분리
- $AUC \geq 0.7$



[그림 2] 공격 모델 구조

1.4 핵심 결과

지표	결과
----	----

Target Accuracy	0.8971
Attack Accuracy	0.800
AUC	0.487
$\Delta\mu(\text{top-1})$	-0.00097
Tail Fraction	0.25%

ROC Curve 분석 결과 AUC는 0.487로 무작위 분류기(0.5)에 근접하였다. 이는 membership 여부에 대한 통계적으로 유의미한 분리 신호가 존재하지 않음을 의미한다. Attack Accuracy가 0.800으로 나타났으나, Confusion Matrix 분석 결과 단일 클래스 예측 경향(degenerate behavior)이 확인되었으며, 이는 클래스 불균형에 따른 착시 효과로 판단된다. 따라서 본 실험에서는 유의미한 Membership Inference 성공 사례는 확인되지 않았다.

1.5 최종 리스크 판정

사전 정의된 성공 기준($\text{AUC} \geq 0.7$)을 충족하지 못하였으므로, 본 모델은 기본적인 Black-box 기반 Threshold Membership Inference Attack에 대해 통계적으로 유의미한 취약성을 보이지 않는 것으로 판단된다. 현재 위험도는 Low 수준으로 평가된다.

다만 다음 조건 발생 시 리스크 상승 가능성이 존재한다:

- 모델 과적합 증가
- confidence 노출 범위 확대
- 데이터 분포 변화
- White-box 정보 노출

1.6 수행 개요

- 수행 기간: 2025.07.28 - 2025.11.6 (15주)
- 수행 인력: 5명 (Red Team 3명, Analysis 2명)
- 수행 환경:
 - macOS 15.6.1 (Apple M2)
 - Python 3.13.5
 - TensorFlow 2.15.0
- 수행 역할 (본인):
 - Shadow Model 설계 및 학습
 - Attack Feature Engineering
 - Threshold 기반 Attack Model 구현
 - ROC/AUC 기반 취약성 분석
- 평가 범위:
 - Black-box Membership Inference Attack
 - Threshold 기반 분리 분석
 - Confidence Leakage 통계 검증

2. 분석 목적

최근 머신러닝 기반 서비스는 의료, 금융, 인증 등 민감한 개인정보를 처리하는 영역으로 확대되고 있다. 이러한 환경에서 모델 자체가 새로운 공격 표면(Attack Surface)으로 작용할 가능성이 제기되고 있다. 특히 **Membership Inference Attack**은 모델 출력만으로 학습 데이터 포함 여부를 추론할 수 있어, 기존 데이터 보호 체계를 우회하는 간접적 정보 노출 위험을 초래할 수 있다.

본 분석의 목적은 다음과 같다.

- 대상 머신러닝 모델의 **Membership Inference Attack** 노출 가능성 평가
- **Black-box** 환경에서의 공격 현실성 검증
- 공격 성공 조건 및 실패 원인 분석
- 실서비스 적용 시 보안적 시사점 도출

3. PPRL 시스템 개요

3.1 PPRL 정의

PPRL(Privacy-Preserving Record Linkage)은 서로 다른 기관 간 데이터셋을 직접 식별자를 노출하지 않은 상태에서 연결하기 위한 기술적 프레임워크이다. 일반적인 **Record Linkage**와 달리, PPRL은 개인정보 보호를 전제로 설계되며 다음과 같은 기법을 활용한다.

- Bloom Filter 기반 암호화 인코딩
- Secure Multi-Party Computation
- Hash 기반 Blocking 전략
- Privacy-preserving similarity learning

PPRL의 핵심 목적은 데이터 공유 없이 레코드 간 동일성 또는 유사성을 판단하는 것이며, 이는 의료, 금융, 공공 행정 영역에서 활용된다.

3.2 의료 데이터 연계 맥락

의료 데이터는 주민등록번호, 병력 정보, 처방 기록 등 고위험 민감정보를 포함한다. 따라서 직접적인 데이터 통합은 개인정보보호법 및 **GDPR**과 같은 규제에 의해 엄격히 제한된다. PPRL은 이러한 규제 환경에서 데이터 분석 및 연계를 가능하게 하는 대안적 접근 방식으로 등장하였다. 그러나 모델 기반 매칭이 포함되는 경우, 출력 확률 분포가 새로운 공격 표면(Attack Surface)이 될 가능성이 존재한다.

3.3 개인정보 보호 설계 의도

PPRL 시스템은 다음과 같은 보안 설계 가정을 전제로 한다.

1. 직접 식별자 제거
2. 암호화된 특징 공간 사용
3. 원본 데이터 비공개
4. 매칭 결과만 제공

그러나 이러한 설계는 “데이터 레벨 보호”에 초점을 둔 접근이다. 본 연구는 모델 출력 레벨에서 발생할 수 있는 간접적 프라이버시 노출 가능성을 검증한다. 즉, PPRL이 데이터 자체는 보호하더라도, 모델이 학습한 통계적 패턴이 **membership inference**를 통해 우회적으로 노출될 수 있는지 평가하는 것이 본 연구의 핵심 문제 설정이다.

3.4 ML 모델의 역할

본 시스템에서 ML 모델은 **Siamese Network** 기반 유사도 임베딩을 생성하고, 최종 MLP 분류기를 통해 매칭 여부를 확률값 형태로 출력한다.

출력은 다음과 같은 형태를 가진다:

`P(match | record1, record2)`

이 확률값은 직접적인 개인정보를 포함하지 않지만, 학습 데이터에 포함된 샘플의 경우 일반적으로 더 높은 **confidence**를 보이는 경향이 존재할 수 있다. 이는 **Membership Inference Attack**의 기반 가설이 된다. 따라서 본 연구는 “PPRL 구조가 데이터 보호를 보장하더라도, 모델 **confidence** 분포 차이가 새로운 간접 공격 벡터가 될 수 있는가?”라는 질문을 검증한다.

4. 분석 범위

4.1 대상 시스템

본 평가의 대상은 학습이 완료된 **SNN+MLP** 기반 분류 모델(`target_model.h5`)이며, 실제 운영 환경에서 **API** 형태로 배포되어 **softmax** 확률 벡터를 반환하는 구조를 가정하였다. 모델 내부 파라미터, 학습 데이터, **gradient** 정보는 외부에 노출되지 않으며, 공격자는 오직 추론 요청을 통해 확률 출력값을 획득할 수 있는 환경으로 정의하였다. 이는 실제 클라우드 ML API 배포 환경과 동일한 위협 모델을 반영한다.

4.2 분석 포함 범위

본 분석은 다음 범위에 한정하여 수행되었다.

- Black-box 환경에서의 Shadow Model 기반 Membership Inference Attack
- Confidence 분포 차이에 기반한 Threshold 분리 전략

- ROC Curve 및 AUC 지표를 통한 통계적 분리 가능성 평가
- Train/Test confidence 평균 차이($\Delta\mu$) 및 tail fraction 분석

본 평가는 모델의 출력 분포 기반 간접 정보 노출 가능성에 초점을 두며, 데이터 레벨 공격이 아닌 모델 출력 레벨 공격을 대상으로 한다.

4.3 제외 범위

본 평가는 다음 항목을 포함하지 않는다.

- White-box 공격 (모델 파라미터 접근 필요)
- Gradient 기반 공격 (Deep Leakage from Gradients 등)
- 모델 파라미터 복원 (Model Extraction)
- 원본 데이터 탈취 (Data Exfiltration)

이는 본 연구가 실제 서비스 배포 환경에서 현실적으로 가능한 **Black-box** 공격 시나리오를 우선적으로 검증하기 위함이다. **White-box** 또는 **gradient** 기반 공격은 보다 강력한 위협 모델에 해당하며, 별도의 고도화 연구 영역으로 분리된다.

5. 위협 모델 정의

5.1 공격자 가정

본 평가는 **Black-box** 환경을 전제로 한 위협 모델을 적용하였다. 공격자는 다음과 같은 능력을 가진 것으로 가정한다.

- 모델에 대한 무제한 또는 반복적 추론 요청 가능
- softmax 확률 벡터 출력 획득 가능
- 모델 내부 구조, 학습 데이터, 파라미터 접근 불가
- gradient 정보 접근 불가

공격자는 모델을 서비스 형태로 소비하는 일반 **API** 사용자 수준의 권한만 보유한다. 이는 실제 클라우드 기반 **ML API** 배포 환경에서 현실적으로 발생 가능한 위협 시나리오를 반영한다.

5.2 공격 목표

공격의 목표는 단일 입력 샘플이 모델 학습 데이터에 포함되었는지 여부를 추론하는 것이다.

Membership 추론이 가능할 경우, 이는 다음과 같은 보안적 의미를 가진다:

- 특정 환자 레코드가 학습 데이터에 포함되었는지 노출
- 데이터셋 참여 여부를 통한 간접 재식별 가능성 증가
- 데이터 활용 범위에 대한 정보 유출

- 민감 데이터 처리 사실의 외부 노출

특히 의료 데이터 환경에서는 “학습 데이터에 포함되었다”는 사실 자체가 개인정보에 해당할 수 있다.

5.3 공격 시나리오 개요

본 평가는 **Black-box** 환경을 가정한 **Membership Inference Attack** 시나리오에 기반한다. 공격자는 **Target** 모델의 내부 구조, 학습 데이터, 파라미터에 접근할 수 없으며, 오직 **softmax** 확률 출력만을 관찰할 수 있다고 가정하였다. 공격의 핵심 가설은 다음과 같다: “학습 데이터에 포함된 샘플은 비학습 데이터에 비해 더 높은 **confidence**를 보일 가능성이 있다.” 이는 과적합(**overfitting**) 또는 **memorization** 현상에 기인한다.

공격 절차는 다음과 같다:

1. **Target** 모델과 동일한 아키텍처의 **Shadow** 모델을 독립 데이터로 학습
2. **Train/Test confidence** 분포 수집
3. **Confidence** 분포 차이를 기반으로 **Membership Classifier** 학습
4. **Target** 모델 출력에 **Attack Model** 적용
5. **ROC/AUC** 기반 분리 가능성 평가

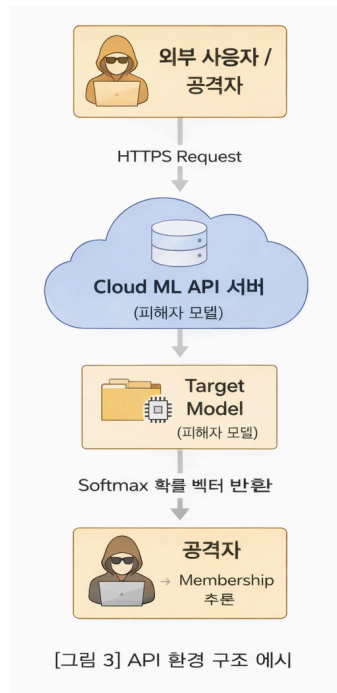
해당 구조는 학습 데이터에 직접 접근하지 않고도 모델 출력만으로 **membership** 추론이 가능함을 검증하는 공격 모델이다.

5.4 비즈니스 리스크

공격이 성공할 경우 다음과 같은 실질적 리스크가 발생할 수 있다:

- 특정 개인의 의료 기록 학습 여부 노출
- **PPRL** 설계 목적(비식별 연계)의 구조적 우회
- **GDPR Article 5** 및 데이터 최소화 원칙 위반 가능성
- 민감정보 처리 사실의 외부 유출
- 기관 신뢰도 하락 및 법적 책임 발생 가능성

특히 **PPRL** 환경에서는 직접 식별자가 제거되었더라도, 모델 기반 간접 노출은 보호 설계의 우회 경로가 될 수 있다.



6. 공격 시나리오 상세

본 실험은 **Black-box** 환경에서 현실적으로 수행 가능한 **Shadow Model** 기반 **Membership Inference Attack(MIA)** 구조를 채택하였다. 공격자는 **Target** 모델의 내부 구조, 학습 데이터, 파라미터에 접근할 수 없으며, 오직 **softmax** 확률 벡터만을 관찰 가능한 상황을 가정하였다. 공격 절차는 앞서 정의한 5단계 구조(S-01 ~ S-05)에 따라 수행되었으며, 각 단계는 피해자 모델 확보, 대체 모델 학습, 공격 모델 구성, 최종 적용 단계로 구분된다. 본 단계에서는 공격 성공 여부를 사전에 정의된 정량적 기준에 따라 평가하였다.

공격 성공 판단 기준

공격 성공은 단순 **Accuracy**가 아닌, 분리 능력(**discrimination power**)에 기반하여 판단하였다.

다음 조건을 충족할 경우 공격 성공으로 정의하였다:

1. **Target Model**의 Train/Test confidence 평균 차이($\Delta\mu$)가 통계적으로 유의미할 것
2. **ROC Curve**가 무작위 분류기(대각선) 대비 명확한 분리 양상을 보일 것
3. **Attack Model**의 $AUC \geq 0.7$

$AUC \geq 0.7$ 기준은 보안 연구 문헌에서 실질적 분리 가능성이 존재한다고 판단되는 최소 수준으로 설정하였다. 이는 우연적 분류(0.5)와 명확히 구분되는 수준을 의미한다. 해당 기준은 모델이 학습 데이터를 과도하게 기억하고 있을 경우 나타나는 **confidence leakage** 신호를 정량적으로 검증하기 위함이다.

7. 시스템 및 공격 아키텍처

본 실험은 **Target Model**, **Shadow Models**, **Attack Model**로 구성된 3계층 공격 구조를 따른다. 이 구조는 학습 데이터에 직접 접근하지 않고도 **membership** 추론을 수행하기 위한 간접적 모델링 전략이다.

(1) Target Model

- 클라이언트 제공 피해자 모델
- 실제 운영 환경에서 배포되는 모델
- 내부 구조 및 파라미터 비공개
- 공격 대상

Target 모델은 공격자가 직접 접근할 수 없는 블랙박스 환경에 존재한다.

(2) Shadow Models (1~6)

- 공격자가 독립적으로 학습한 모방 모델
- **Target**과 동일한 아키텍처 사용
- 독립 데이터셋 기반 학습
- **membership ground-truth** 확보 가능

Shadow 모델의 목적은 **Target** 모델의 **confidence** 분포 특성을 근사(approximation)하는 것이다. 이를 통해 공격자는 **membership** 분리 패턴을 학습할 수 있다.

(3) Attack Model

- **Shadow** 모델 출력 기반 **membership classifier**
- **Threshold** 기반 분리 전략 사용
- 최종적으로 **Target** 모델 출력에 적용

Attack Model은 **Shadow** 단계에서 학습된 **confidence** 분리 기준을 **Target** 모델 출력에 적용하는 최종 공격기이다.

전체 공격 단계 요약

S-01 Target Model Training

S-02 Shadow Dataset Preparation

S-03 Shadow Model Training

S-04 Attack Model Training

S-05 Attack Execution

이 5단계 구조는 실제 클라우드 기반 **ML** 서비스 환경에서 가능한 공격 흐름을 재현한다.

8. 데이터 구성 및 산출물 정의

본 장에서는 **Target Model**, **Shadow Models**, **Attack Model** 구성에 사용된 데이터 자산 및 산출물을 정의한다. 본 프로젝트는 재현성(reproducibility)과 무결성(integrity)을 확보하기 위해 데이터 자산 관리 체계를 명확히 문서화하였다.

8.1 데이터 자산 개요

본 프로젝트는 다음 3계층 데이터 흐름을 따른다:

1. **Target** 모델 학습 및 평가 데이터
2. **Shadow** 모델 구성용 대체 데이터셋
3. **Attack** 모델 학습을 위한 **confidence** 집계 데이터

각 단계는 독립적으로 관리되며, 데이터 누수(Data Leakage)를 방지하기 위해 엄격히 분리되었다.

8.2 Target Model 데이터

(1) 입력 데이터

구분	파일명	형식	사용 목적
원본 데이터	target_train.csv	CSV	모델 학습
원본 데이터	target_test.csv	CSV	모델 평가
임베딩 벡터	x1_target_*.npy	NumPy	Siamese 입력
임베딩 벡터	x2_target_*.npy	NumPy	Siamese 입력
Label	y_target_*.npy	NumPy	학습 정답

임베딩 데이터는 전처리 완료 상태로 제공되었으며, 직접 식별자는 포함되지 않는다.

(2) 실행 및 산출물

구분	파일명	설명
실행 파일	SNN+MLP.ipynb	Target 모델 학습
모델 파일	target_model.h5	최종 추론 모델
모델 파일	snn_classifier_model.h5	내부 분류기
결과 파일	final_test_predictions_raw_np.csv	softmax 출력
시각화	confusion_matrix.png	성능 검증

모든 모델 파일은 **SHA256** 해시를 기록하여 무결성을 검증하였다.

8.3 Shadow Dataset 구성

(1) 원본 데이터

파일명
shadow_train.csv
shadow_test.csv

(2) 분할 전략

항목	내용
Shadow Model 수	6개
분할 방식	비중첩(equal split)
중복률	0%
Row 보존율	100%
Membership Label	Train=1 / Test=0

Shadow 모델은 Target 모델과 동일한 아키텍처를 사용하여 confidence 분포를 근사하기 위해 학습되었다.

(3) 산출물

파일명	설명
Shadow1~6_combined_predictions.csv	Confidence + Membership Label

전체 약 40,000개 샘플이 Attack Dataset 구성에 사용되었다.

8.4 Attack Dataset 생성

(1) 실행 파일

MIA_Attack_Final_v2.ipynb

(2) 입력

파일명
Shadow*_combined_predictions.csv

(3) Feature Engineering

Feature	설명	보안적 의미
max_confidence	최고 softmax 값	membership 분리 신호
entropy	확률 분포 불확실성	confidence leakage 지표
top2_gap	상위 2개 확률 차이	결정 경계 근접도
boundary_distance	decision boundary 거리	과적합 탐지 보조
is_member	정답 label	membership ground-truth

(4) 산출물

파일명	설명
aggregated_attack_dataset.csv	공격 학습 데이터
ROC_AUC.png	ROC Curve
attack_eval.log	실행 로그
kpi_summary.csv	KPI 정리

8.5 Attack Execution 단계

(1) 실행 파일

- MIA_Attack_Final_v2.ipynb

구분	내용
입력	target_model.h5
입력	target_test.csv
출력	ROC Curve
출력	Confusion Matrix
출력	$\Delta\mu(\text{top-1})$
출력	KPI Summary

이 단계에서만 Target 모델이 실제 공격 대상이 된다.

(2) 산출물

산출물
ROC Curve 이미지
Confusion Matrix
$\Delta\mu(\text{top-1})$ 결과
KPI summary 로그

8.6 파일 무결성 및 추적성

항목	내용
모델 무결성	SHA256 해시 기록
CSV 검증	Shadow Output hash 검증
Seed 고정	seed = 42
환경	macOS 15.6.1 / Python 3.13.5 / TF 2.15.0

모든 Notebook 실행 로그는 재현 가능한 상태로 관리되었으며, 동일 환경에서 동일 결과 도출이 가능하다.

9. Membership Inference Attack Execution Framework

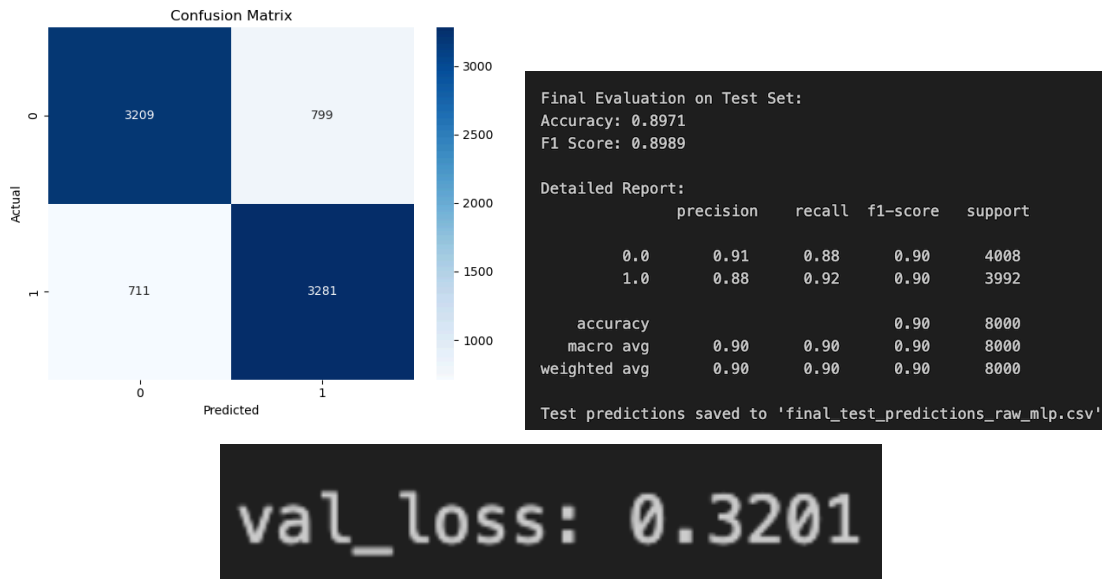
9.1 Phase S-01 - Target Model Baseline 평가

Target Model은 클라이언트 제공 코드(SNN+MLP.ipynb)를 기반으로 학습 및 재현하였다. 본 단계는 공격이 아닌 피해자 모델 확보 및 정상 동작 검증 단계이다.

Baseline 성능은 다음과 같다.

- Accuracy: 0.8971
- F1-score: 0.8989
- Validation Loss: 0.3201

사전 정의된 Metric Gate 조건($\text{Accuracy} \geq 0.70$, $\text{Validation Loss} \leq 0.5$)을 충족하였다. Confusion Matrix 및 학습 곡선 분석 결과, 학습/검증 간 성능 격차가 과도하지 않았으며, 뚜렷한 과적합 징후는 관찰되지 않았다. 이는 이후 Membership Inference Attack 성공 가능성과 직접적으로 연관되는 중요한 기초 지표이다.



[그림 4] Target Model 결과

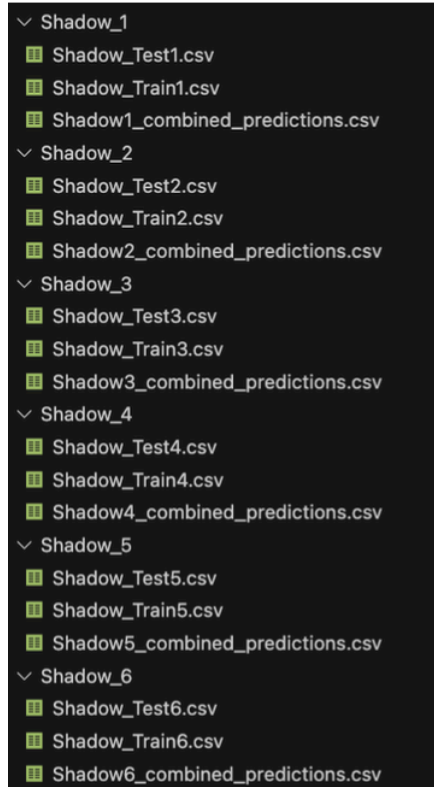
9.2 Phase S-02 - Shadow Dataset Preparation

공격자는 Target 모델의 학습 데이터에 접근할 수 없으므로, 독립적인 Shadow Dataset을 구성하였다.

Shadow Dataset은 다음 기준에 따라 설계되었다:

- 총 6개 비중첩 서브셋 생성
- 중복률 0%
- row 보존율 100%
- 클래스 균형 오차 $\pm 10\%$ 이내

각 Shadow Train set은 member로, Shadow Test set은 non-member로 정의되었다. 이 구조는 공격자가 membership ground-truth를 확보한 상태에서 Attack Model을 학습하기 위한 기반을 제공한다.



[그림 5] Dataset Split

9.3 Phase S-03 - Shadow Model 학습 결과

각 Shadow Model은 Target과 동일한 아키텍처(SNN+MLP)로 학습되었다.

평균 성능:

- Train Accuracy: 77.8%
- Test Accuracy: 73.6%
- Generalization Gap: 3.5%
- Overfit Ratio: 1.02 ~ 1.15

Generalization Gap이 제한적 범위에 머물러 있으며, 과도한 과적합은 관찰되지 않았다. 이는 Shadow 모델에서 train/test confidence 분포 차이가 크지 않음을 의미하며, membership 분리 신호가 약할 가능성을 시사한다.

Metrics

Model Performance Overview			
Shadow Model	Train Accuracy	Test Accuracy	Accuracy Gap
1	77.7%	74.3%	3.4%
2	78.4%	74.8%	3.6%
3	77.1%	74.9%	2.2%
4	78.4%	75.5%	2.9%
5	77.7%	72.5%	5.2%
6	73.2%	69.2%	3.9%

[그림 6] Shadow Model Train/Test 비교 그래프

9.3.1 Shadow Model Implementation Highlights

Shadow Model은 Target과 동일한 아키텍처(SNN+MLP)를 기반으로 구성되었으며, 데이터 누수를 방지하기 위해 전체 데이터를 균등 분할하여 비중첩 구조를 유지하였다.

(1) 데이터 분할 전략

Shadow Model 학습을 위해 전체 Shadow 학습/테스트 데이터를 동일 크기의 비중첩 서브셋으로 분할하였다. 각 모델은 독립적인 membership ground-truth를 보유하도록 설계되었다.

핵심 분할 로직은 다음과 같다.

```
train_split_size = len(y_train_full) // num_models
test_split_size = len(y_test_full) // num_models

train_start = model_idx * train_split_size
train_end = (model_idx + 1) * train_split_size
```

위 전략을 통해:

- 각 Shadow Model은 서로 다른 데이터 영역을 학습
- 샘플 중복률 0% 유
- membership label의 독립성 확보

이는 공격자가 현실 환경에서 독립적인 대체 데이터셋을 확보하여 Shadow Model을 구성하는 상황을 모사하기 위한 설계이다.

(2) Overfitting 통제 로직

Membership Inference Attack은 모델의 과적합(overfitting) 수준과 밀접하게 연관된다. 따라서 각 Shadow Model에 대해 일반화 성능을 정량적으로 측정하였다.

평가 지표는 다음과 같다.

```
overfitting_ratio = val_loss / train_loss
```

```
generalisation_gap = val_loss - train_loss
```

- Overfitting Ratio > 1.0: 검증 손실이 학습 손실보다 큼
- Generalisation Gap 증가: train/test confidence 분리 가능성 상승

과도한 generalisation gap은 confidence leakage 신호를 인위적으로 증폭시켜 MIA 성공률을 왜곡할 수 있다.

그러나 본 실험에서는:

- Generalisation Gap 평균 3.5%
- Overfitting Ratio 1.02 ~ 1.15

수준으로 제한적 범위에 머물렀으며, 의도적인 과적합 증폭 없이 공격 실험이 수행되었음을 확인하였다.

(3) Hybrid Loss 기반 Representation 안정화 설계

Shadow Model은 단순 Binary Cross-Entropy 기반 분류기가 아니라, Contrastive Loss와 Reconstruction Loss를 결합한 Hybrid Loss 구조를 사용하였다.

핵심 설계는 다음과 같다.

```
def hybrid_classification_loss(self, margin=2.5, alpha=1.0):

    distances = tf.norm(encoded1 - encoded2, axis=1)

    contrastive_loss = y_true * tf.square(distances) + \
        (1 - y_true) * tf.square(tf.maximum(margin - distances, 0))

    recon_loss1 = tf.reduce_mean(tf.square(encoded1 - recon1), axis=1)
    recon_loss2 = tf.reduce_mean(tf.square(encoded2 - recon2), axis=1)

    return tf.reduce_mean(
        alpha * 0.5 * (recon_loss1 + recon_loss2) + contrastive_loss
    )
```

설계 의도

- Contrastive Loss
 - 유사 레코드는 임베딩 공간에서 가깝게, 비유사 레코드는 일정 margin 이상 떨어지도록 학습
 - 매칭 모델의 핵심 목적을 반영
- Reconstruction Loss
 - 인코딩된 표현이 원본 임베딩 특성을 유지하도록 유도
 - 표현 공간의 안정성 확보

보안적 의미

Membership Inference Attack은 모델이 학습 데이터를 과도하게 기억(memorization)할 때 성공 확률이 높아진다.

Hybrid Loss 구조는:

- 과도한 confidence 집중 완화
- 임베딩 공간의 과적합 억제
- train/test confidence 분포 차이 감소

를 유도한다.

즉, 본 Shadow Model은 단순히 Target을 모방하는 것이 아니라, 일반화 성능을 유지하면서도 현실적인 공격 환경을 재현하도록 설계되었다. 이는 MIA 성공 가능성에 직접적인 영향을 미치는 핵심 설계 요소이다.

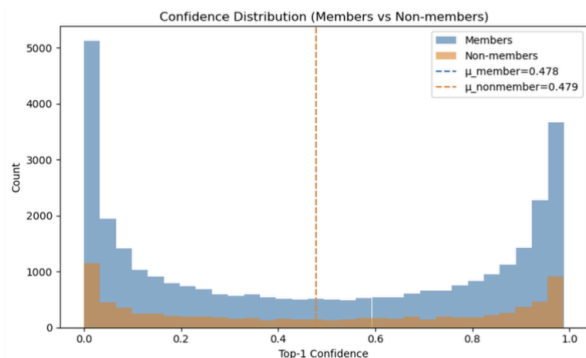
9.4 Confidence 분포 분석

Shadow Model의 Train/Test confidence 분포를 분석한 결과:

- $\Delta\mu(\text{top-1}) = -0.00097$
- Tail Fraction = 0.25%

Histogram 및 KDE 분석 결과, train/test 간 평균 confidence 차이는 통계적으로 유의미하지 않았다. 이는 membership 여부에 따른 통계적 confidence leakage 신호가 거의 존재하지 않음을 의미하며, Attack Model이 유의미한 분리 기준을 학습하기 어려운 환경이었음을 시사한다.

```
Metric, Value
Δμ(top1), -0.0009666509417258218
μ_member, 0.4781311586494908
μ_nonmember, 0.4790978095912166
Δμ>0?, False
p>0.95_member, 0.1333770942735684
p>0.95_nonmember, 0.12345370486067725
```



[그림 7] Histogram + KDE Plot

9.5 Phase S-04 - Attack Model Training

Shadow Model 출력값을 집계하여 **Attack Dataset**을 구성하였다.

Feature Engineering 항목:

- max_confidence
- entropy
- top2_gap
- boundary_distance

Shadow Train → member(1)

Shadow Test → non-member(0)

이를 기반으로 Threshold 기반 Membership Classifier를 학습하였다.

9.5.1 Threshold 기반 Membership Classifier 구현 로직

Membership 분리 기준은 단순 평균이 아닌 ROC 기반 최적 threshold 탐색을 통해 도출되었다.

```
fpr, tpr, thresholds = roc_curve(shadow_labels, shadow_conf)
roc_auc = auc(fpr, tpr)

j_scores = tpr - fpr
optimal_idx = np.argmax(j_scores)
optimal_threshold = thresholds[optimal_idx]
```

Youden's J statistic을 활용하여 분리 능력을 최대화하는 threshold를 선택하였다. 본 실험에서는 AUC가 0.5에 근접하여 통계적으로 유의미한 분리 신호는 확인되지 않았다.

9.6 Phase S-05 - Attack Execution

학습된 Attack Model을 Target 모델 출력에 적용하였다.

공격 절차:

1. victim dataset을 Target 모델에 질의
2. softmax 확률 벡터 수집
3. Attack Model 입력
4. membership 여부 예측

본 단계에서 처음으로 Target 모델이 공격 대상이 된다.

9.6.1 Target 적용 로직

학습된 threshold는 Target 모델 출력 confidence에 적용되었다.

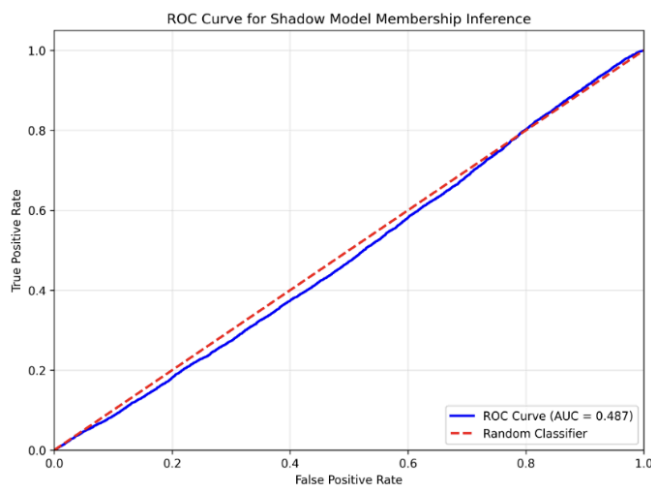
```
target_conf = target_df['Confidence'].values
target_pred = (target_conf > optimal_threshold).astype(int)
fpr = np.mean(target_pred == 1)
```

False Positive Rate(FPR)는 테스트 데이터가 학습 데이터로 오인되는 비율을 의미하며, membership 추론 공격의 실질적 성공 가능성을 나타내는 지표로 활용되었다.

9.7 공격 결과

- Accuracy: 0.800
- F1: 0.889
- AUC: 0.487

AUC가 0.5에 근접함에 따라, 본 실험 조건에서는 membership 분리가 통계적으로 의미 있는 수준으로 나타나지 않았다.



```
=== ATTACK RESULTS ===
Attack Accuracy: 0.8000
Attack F1 Score: 0.8889
```

[그림 8] Attack Model ROC Curve + 결과

10. 결과 심층 분석

Attack Accuracy는 0.800으로 나타났으나, ROC-AUC는 0.487로 무작위 분류기(0.5) 수준에 근접하였다. 이는 모델이 membership 여부를 실질적으로 구분하지 못했음을 의미하며, 단순 정확도 지표가 실제 분리 능력을 반영하지 못한 사례로 해석된다. $\Delta\mu(\text{top-1})$ 은

-0.00097로 거의 0에 수렴하였고, Tail Fraction 또한 0.25%로 매우 낮은 수준을 보였다. 이는 Target 모델의 train/test confidence 분포 간 통계적으로 유의미한 차이가 존재하지 않음을 나타낸다. 즉, membership 여부에 따른 confidence leakage 신호가 거의 관찰되지 않았으며, Attack Model이 학습할 수 있는 분리 기준(discriminative signal)이 사실상 존재하지 않았음을 의미한다.

종합적으로 볼 때, 본 실험 조건 하에서 Target 모델은 과도한 overfitting 상태에 있지 않았으며, Black-box 기반 Threshold Membership Inference Attack에 대해 상대적으로 안정적인 상태를 유지하고 있는 것으로 판단된다. 이는 모델이 학습 데이터에 대해 과도한 memorization을 보이지 않았음을 간접적으로 시사한다.

11. PPRL 맥락에서의 보안 영향 평가

PPRL(Privacy-Preserving Record Linkage)은 직접 식별자를 노출하지 않고 기관 간 데이터 연계를 수행하도록 설계된 구조이다. 따라서 시스템 설계의 핵심 목적은 “식별 정보의 비노출”과 “연계 정확도 유지” 간 균형을 확보하는 것이다. 그러나 Membership Inference Attack이 성공할 경우, 직접 식별 정보가 노출되지 않더라도 특정 레코드가 학습 과정에 포함되었는지 여부가 추론될 수 있다.

이는 다음과 같은 보안적·규제적 영향을 초래할 수 있다:

- 특정 환자 데이터의 학습 참여 여부 노출
- PPRL의 설계 취지와의 구조적 충돌
- 간접적 재식별 위험 증가
- GDPR 및 개인정보보호법 상 민감정보 처리 위반 가능성
- 기관 신뢰도 및 평판 리스크 확대

특히 의료 데이터와 같이 민감성이 높은 환경에서는, 단순 “데이터 포함 여부” 정보조차 개인 프라이버시에 중대한 영향을 미칠 수 있다. 이는 데이터 자체의 노출이 아닌, 모델 출력 기반 간접 정보 추론이라는 점에서 더욱 탐지와 통제가 어렵다. 그러나 본 실험에서는 confidence 분포 차이 및 ROC-AUC 분석 결과, 통계적으로 유의미한 membership leakage 신호가 관찰되지 않았다. 따라서 현재 모델은 기본적인 Black-box 기반 Threshold Membership Inference Attack에 대해 상대적으로 안정적인 상태를 유지하고 있는 것으로 평가된다. 다만, 모델 과적합 증가, confidence 출력 범위 확대, 데이터 분포 변화, White-box 정보 노출 등의 조건이 추가될 경우 리스크 수준이 상승할 가능성은 배제할 수 없다.

12. 종합 리스크 판정

본 평가 결과, 대상 PPRL 기반 머신러닝 모델은 Black-box 환경에서의 Threshold 기반 Membership Inference Attack에 대해 통계적으로 유의미한 취약성을 보이지 않았다. ROC-AUC가 0.5 수준에 근접하였으며, confidence 분포 간 평균 차이($\Delta\mu$) 또한 0에

수렴하여 실질적인 **membership** 분리 신호는 관찰되지 않았다. 이에 따라 현재 위험도는 **Low** 수준으로 판정한다.

리스크 평가 요약

항목	평가	근거
위험도	Low	$AUC \approx 0.5$, $\Delta\mu \approx 0$
공격 난이도	Medium	Shadow Model 구성 필요
재현성	확보	실험 로그 및 seed 고정
고도화 시 상승 가능성	존재	White-box, DP 미적용

13. 대응 방안

Membership Inference Attack은 모델의 과적합 수준 및 **confidence** 출력 특성과 밀접하게 연관된다. 따라서 대응 전략은 **Training** 단계, **Output** 단계, 운영 단계를 포함하는 다층적 방어 구조(Layered Defense Model)로 설계하는 것이 바람직하다.

13.1 기술적 대응 방안

(1) Differential Privacy (DP-SGD 적용)

학습 단계에서 Differential Privacy를 적용하여 모델이 개별 샘플에 과도하게 의존하지 않도록 제어할 수 있다.

- Gradient clipping
- Noise injection
- Privacy budget (ϵ) 관리

DP는 학습 데이터의 포함 여부에 대한 통계적 추론 가능성을 이론적으로 제한한다는 점에서 가장 근본적인 대응 전략이다.

(2) Output Perturbation

모델 출력 **confidence** 값에 소량의 **noise**를 추가하거나, 확률 정밀도를 제한함으로써 공격자가 분포 차이를 학습하기 어렵게 만들 수 있다.

예시:

- Confidence 소수점 절삭
- Temperature scaling 적용
- Top-1 label만 반환

이는 Black-box 기반 공격을 직접적으로 약화시키는 효과가 있다.

(3) Regularization 강화

L2 regularization, Dropout, Early stopping 등을 통해 과적합을 억제하면 train/test confidence 차이를 감소시킬 수 있다. Membership Inference Attack은 과적합 수준과 높은 상관관계를 가지므로, 일반화 성능 향상은 곧 프라이버시 강화로 이어진다.

13.2 운영적 대응 방안

(1) Query Rate 제한

API 호출 횟수 및 패턴을 제한하여 대량의 confidence 수집을 방지한다.

- Rate limiting
- IP 기반 요청 차단
- 이상 질의 탐지

(2) Confidence 출력 축소

필요 이상으로 상세한 softmax 벡터를 반환하지 않도록 정책을 수립한다.

- Binary label만 반환
- Confidence 범위 구간화
- 확률 벡터 비공개

13.3 Layered Defense Model

Layer	통제 영역	목적
Layer 1	Training Control	과적합 및 memorization 억제
Layer 2	Output Control	Confidence leakage 최소화
Layer 3	Monitoring Control	이상 질의 및 공격 탐지

단일 대응책은 우회될 가능성이 있으므로, 다층 방어 구조를 적용하는 것이 권장된다.

보안적 시사점

현재 모델은 기본적인 Black-box MIA에 대해 Low Risk 수준이나, 모델 배포 환경에서 confidence 노출 정책이 완화될 경우 위험도가 상승할 수 있다. 따라서 기술적 통제와 운영적 통제를 병행하는 방어 전략이 필요하다.

14. 한계점

본 분석은 **Black-box** 기반 **Threshold Membership Inference Attack**에 초점을 맞추어 수행되었으며, 다음과 같은 한계가 존재한다.

(1) 단일 데이터셋 기반 평가

본 실험은 단일 의료 데이터셋을 기반으로 수행되었다. 데이터 분포 특성, 클래스 불균형, 샘플 규모에 따라 **membership** 분리 신호는 달라질 수 있다. 따라서 다른 도메인 데이터셋에 동일한 결과가 일반화된다고 단정할 수 없다.

(2) **Threshold** 기반 공격 전략에 한정

본 실험에서는 **ROC** 기반 **threshold classifier**만을 사용하였다.

그러나 최근 연구에서는 다음과 같은 고도화 기법이 제안되고 있다:

- **Neural-network** 기반 **attack model**
- **Meta-classifier** 기반 **membership inference**
- **Loss-based inference**
- **Adaptive shadow modeling**

이러한 고급 공격 기법을 적용할 경우 공격 성능이 달라질 가능성이 존재한다.

(3) **White-box** 및 **Gradient** 기반 공격 미검증

본 평가는 **Black-box** 환경을 가정하였다. 모델 내부 파라미터 또는 **gradient** 정보에 접근 가능한 **White-box** 환경에서는 더 강력한 공격이 가능할 수 있다. 따라서 본 결과는 **Black-box** 환경에 한정된 평가 결과이다.

(4) **Entropy** 및 **Calibration** 기반 고도화 분석 미수행

Confidence entropy, **temperature scaling**, **calibration error(ECE)** 등 추가적인 통계 분석을 수행하지 않았다. 출력 분포 정규화 여부에 따라 **membership** 추론 가능성이 달라질 수 있다.

정리

본 연구는 기본적인 **MIA** 구조에 대한 1차적 평가로서 의미를 가지며, 고도화 공격 기법에 대한 추가 검증이 향후 필요하다.

15. 결론

본 분석을 통해 대상 **PPRL** 기반 머신러닝 매칭 모델은 기본적인 **Black-box Membership Inference Attack**에 대해 통계적으로 유의미한 취약성을 보이지 않는 것으로 확인되었다. **ROC-AUC**는 **0.487**로 무작위 분류기 수준에 머물렀으며, **train/test confidence** 평균 차이 또한 통계적으로 유의미하지 않았다. 이는 모델이 학습 데이터에 대해 과도한 **memorization**을 보이지 않았음을 간접적으로 시사한다.

다만 다음 조건이 발생할 경우 프라이버시 리스크는 상승할 수 있다:

- 모델 과적합 수준 증가
- **Confidence** 출력 정책 완화
- 데이터 분포 변화
- **White-box** 정보 노출

본 연구는 **PPRL** 환경에서도 머신러닝 모델 자체가 새로운 공격 표면이 될 수 있음을 실증적으로 검증하였으며, 모델 배포 이전 단계에서 프라이버시 취약성 평가 절차를 포함하는 것이 필요함을 시사한다. 또한 **AI** 기반 시스템에서 보안은 데이터 보호 설계만으로 완성되지 않는다. 모델의 일반화 특성과 출력 정책까지 포함한 통합적 프라이버시 검증이 필수적이다.